GDPR / PII DLP Pack — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — GDPR / PII DLP Pack (Microsoft Purview) 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 5

Boundaries (so scope is clear) . . . 5

1. Solution Overview — GDPR / PII DLP Pack (Microsoft Purview) 5

What this solution is . . . 5

Why this matters . . . 6

How it works . . . 6

The five DLP locations (and what each controls for personal data) . . . 7

The simulate→enforce journey (the core discipline) . . . 8

What you can control . . . 8

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 9

2. Requirements — GDPR / PII DLP Pack (Microsoft Purview) 9

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP . . . 9

2.2 DLP-specific least-privilege roles . . . 10

2.3 Devices onboarded to Purview for Endpoint DLP . . . 10

2.4 A personal-data classification intent and an EU-PII SIT inventory . . . 11

2.5 Source data for Exact Data Match (only if EDM is used) . . . 11

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific) . . . 12

2.7 An incident/alert triage owner and destination . . . 12

Global Requirements — Microsoft Purview Solutions 13

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 14

2. Purview roles (least-privilege) and portal access . . . 14

3. Security & Compliance PowerShell + Graph toolchain . . . 14

4. Data sources & scope in scope . . . 14

5. Compliance, records, privacy & legal stakeholders . . . 15

6. A pilot scope and change control . . . 15

3. Implementation Guide — GDPR / PII DLP Pack (Microsoft Purview) 15

Phase 0 — Connect and baseline (Assess) . . . 16

Phase 1 — Design the classification layer (SITs & classifiers for EU personal data) . . . 16

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact) . . . 17

Phase 3 — Measure and tune (drive false positives down) . . . 18
Phase 4 — Enforce in a pilot ring (Pilot) . . . 19
Phase 5 — Expand and harden (Enforce → Operate) . . . 19
Order-of-operations summary . . . 20
5. Testing & Validation — GDPR / PII DLP Pack (Microsoft Purview) 20
Test A — Detection & enforcement (personal-data leaks are blocked) . . . 20
Test B — False-positive rate (adoption gate) . . . 21
Test C — Incident / alert handling (the control is operable) . . . 22
Simulation-first & rollback validation . . . 23
Evidence to capture (for the deliverable record) . . . 24
6. Troubleshooting — GDPR / PII DLP Pack (Microsoft Purview) 24
Policy / detection . . . 24
Endpoint DLP . . . 25
False positives (the adoption killer) . . . 26
Alerts / incident handling . . . 26
Connectivity / tooling . . . 27
7. Best Practices — GDPR / PII DLP Pack (Microsoft Purview) 28
Simulate before you enforce — always . . . 28
Get the EU personal-data classification right . . . 28
Tune for a low false-positive rate (adoption depends on it) . . . 29
Respect the GDPR determination boundary . . . 29
Right-size the user experience . . . 29
Endpoint DLP specifics . . . 29
Operations & governance . . . 30
Stay inside the boundary . . . 30
8. Deliverables Summary — GDPR / PII DLP Pack (Microsoft Purview) 30
Documentation . . . 31
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 31
Definition of done . . . 32
Appendix A — PowerShell Scripts 34

Executive Summary — GDPR / PII DLP Pack (Microsoft Purview)

The problem

Personal data relating to identifiable individuals — names tied to national identifiers, passport and tax numbers, financial account data, contact details, and the special-category data that attracts extra protection — leaves the organisation through the channels people use every day: an email with a customer list attached, an "anyone with the link" HR spreadsheet share, a national ID pasted into Teams, or a records file copied to USB or printed from a laptop. GDPR (Regulation (EU) 2016/679) requires that personal data be protected; without a working data-loss control, exposures are invisible until they become a reportable incident. The common failed attempt — switching data-loss controls straight to "block" — floods the help desk with false positives and gets turned off within a week.

The solution

Stand up **Microsoft Purview Data Loss Prevention (DLP)**, tuned for EU personal data, across all five locations — **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. Detection is driven by **sensitive information types** (the EU/GDPR built-in set — national ID, passport, TIN, IBAN, and more — a **custom SIT** for any bespoke national or internal identifier, **trainable classifiers** for special-category data, and **Exact Data Match** against the real records where near-zero false positives matter), and the defining discipline is that **every policy is built and proven in SIMULATION first** — Microsoft's built-in test mode that shows what *would* be blocked, with zero user impact — then tuned for a **low false-positive rate**, then enforced to a **pilot ring**, then expanded. The result: personal-data leaks are blocked without blocking legitimate business.

What it delivers

- A mapped **classification layer** for EU personal data — the right detector for each in-scope category,

reusing the EU/GDPR built-in types and adding a custom SIT / EDM / trainable classifiers only for real gaps.

- **DLP policies across email, cloud, Teams, and endpoint**, each proven in simulation, tuned, and enforced

through policy tips, user justification/override, or block — with optional **cross-border/external-transfer awareness**.

- A **measured false-positive rate** kept at/under an agreed threshold — the difference between a control

staff trust and one they ignore.

- An **incident/alert triage workflow** so every match is acted on, with an evidence trail in Activity

Explorer, least-privilege evidence access, a **DPO/breach hand-off**, and optional SIEM forwarding.

- **Five PowerShell tools** (posture assessment, policy config helper, validation checker, match/false-

positive report, scope helper) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

• **Personal-data leaks blocked** across the channels data actually walks out through — email, cloud sharing,

and USB/print on endpoints — including external/cross-border movement.

• **Minimal disruption** — simulation-first plus tuning means the control catches leaks without a wave of

false positives, and any policy reverts to simulation instantly if needed.

• **Operable and auditable** — matches raise alerts that are triaged to disposition and handed to the DPO for

breach assessment, with evidence retained for a defensible GDPR posture.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and

tooled to run in-house.

Boundaries (so scope is clear)

DLP is licensing-/plan-dependent — **Endpoint DLP and advanced classifiers require E5 / E5 Compliance and onboarded devices** (verify your tenant). This solution provides the **technical configuration and the evidence**; the **lawful basis**, what is **special-category (Article 9)** data, whether a transfer is a **restricted cross-border transfer** and its safeguard, the **enforced action per category**, the retention position, and the **acceptable false-positive threshold** are **data-protection, privacy (DPO), and legal determinations**, captured alongside the delivered evidence.

1. Solution Overview — GDPR / PII DLP Pack (Microsoft Purview)

What this solution is

Personal data relating to identified or identifiable individuals — names tied to national identifiers, passport and tax numbers, contact details, financial account data, and the special-category data that attracts extra protection — leaves an organisation through the same everyday channels everyone uses: an email with a customer list attached, an HR spreadsheet shared "anyone with the link" from OneDrive or SharePoint, a national ID number pasted into a Teams chat, or a file of data-subject records copied to a USB stick or printed from a laptop. **Microsoft Purview Data Loss Prevention (DLP)** detects and controls that movement by matching the *content* being shared against **sensitive information types (SITs)** and **classifiers**, then applying a policy action — audit only, warn the user with a **policy tip**, allow with a business **justification**, or **block** — across **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)**.

This is the **GDPR/PII-aligned DLP pack**: a repeatable, evidence-driven way to stand up EU personal-data detection and protection policies in Microsoft Purview using only the **Microsoft Purview portal**, **Security**

& Compliance PowerShell (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party DLP tooling. Its defining discipline is that **every policy is built and proven in SIMULATION mode first** (Microsoft's built-in test mode that evaluates policy against real traffic and shows what *would* have matched, with zero user impact), tuned for a low false-positive rate, and only then moved to enforcement.

> ***Scope boundary — GDPR determinations are deferred.*** *This solution delivers the **technical method and evidence** for personal-data DLP. *Which* processing is lawful, what constitutes **special-category (Article 9) data**, when a transfer is a **restricted cross-border transfer**, what the **lawful basis** is, the retention position, and the **enforced action** per data category are **data-protection, privacy (DPO), compliance, and legal determinations** — deferred to those functions. The solution helps you configure and prove the control; it does not make the GDPR determination. (GDPR: Regulation (EU) 2016/679 — applicability, lawful basis, and cross-border transfer mechanisms are the organisation's DPO/legal counsel to confirm.)*

Why this matters

- DLP that is switched straight to **enforce** without simulation is the classic failure: it blocks

legitimate business and administration, floods the help desk, and gets disabled within a week. Simulation-first is the difference between a control that survives and one that is turned off.

- **National identifier formats are country-specific.** The EU is not one identifier scheme — passport,

national ID, tax (TIN), and social-security-equivalent numbers differ per member state. Microsoft ships **EU-specific built-in SITs** (and per-country ones), but a bespoke national scheme or an internal data-subject reference usually needs a **custom SIT** (or **Exact Data Match** against a records export) tuned to that format.

- **Special-category data is a policy decision, not a pattern.** Health, biometric, racial/ethnic,

political, religious, and sexual-orientation data (GDPR Article 9) rarely have a clean regex — they need **trainable classifiers** or keyword evidence, and *what* counts as special category is a DPO/legal call.

- **Cross-border transfer is content-plus-context.** DLP can detect personal data leaving to an external or

non-EU recipient, but *whether* that is a restricted transfer (and what safeguard applies) is a legal determination — DLP surfaces the movement and the evidence.

- **Endpoint DLP is licensing- and onboarding-dependent** — it requires the right plan and devices onboarded

to Purview (shared with Microsoft Defender for Endpoint onboarding). A policy scoped to the Devices location does nothing until the endpoints are actually onboarded and reporting.

- False positives are the enemy of adoption. A detector that fires on every internal reference number trains

staff to ignore every policy tip. Tuning — confidence levels, instance counts, supporting keywords, and EDM — is what makes the control usable.

How it works

1. **Sensitive information types (SITs) and classifiers** define *what* to look for. Purview ships 150+

built-in SITs, including an **EU/GDPR-relevant set** — e.g. *EU Passport Number*, *EU National Identification Number*, *EU Social Security Number or Equivalent ID*, *EU Tax Identification Number (TIN)*, *EU Driver's License Number*, *EU Debit Card Number*, *International Banking Account Number (IBAN)*, and *All Full Names* — plus per-country variants. You can add **custom SITs** (regex + keyword + confidence) for local identifiers such as an **internal data-subject reference**, **Exact Data Match (EDM)** SITs (matched against a hashed upload of your real data-subject/records export for near-zero false positives), and **trainable classifiers** for conceptual categories such as special-category data. *Whether a regulatory DLP policy template (for example a GDPR-labeled template) is available in your tenant is licensing-/version-dependent — verify in your tenant; do not assume one exists.*

1. **DLP policies** bind those SITs to **locations** (Exchange, SharePoint, OneDrive, Teams chat/channel, and

Devices/Endpoint) with **conditions** (which SIT, how many instances, what confidence; optionally *recipient is external* for transfer awareness), **actions** (audit / notify / restrict / block; restrict USB/print/cloud-app upload on endpoint), and **user experience** (policy tips, allow-with-justification, allow-override).

1. **Simulation mode** runs the policy against live traffic and records what *would* have matched — with or

without policy tips shown — so you can see the true hit volume and false positives **before** any enforcement. Every policy in this pack starts here.

1. **Tuning** reduces false positives using confidence levels, instance thresholds, supporting keyword

evidence, EDM, and exceptions — measured against the simulation results.

1. **Enforcement** turns the tuned policy on (tips/override/block) in a limited ring, then expands.

2. **Incident/alert handling** — DLP rule matches raise **alerts** in the Purview portal and DLP events flow

to **Activity Explorer**; this pack wires the triage, severity, and response workflow so matches are actually acted on. Because the match evidence *itself* contains personal data, evidence access is kept least-privilege (GDPR data-minimisation applied to the control's own records).

The five DLP locations (and what each controls for personal data)

• **Exchange (email):** customer/HR/marketing lists and data-subject records emailed to unintended or

external recipients; block or encrypt on match, and detect *external-recipient* transfer.

• **SharePoint & OneDrive:** personal-data files at rest and when shared; block external sharing on match.

• **Teams chat & channel messages:** national identifiers or personal-data content pasted into messages.

• **Endpoint (Devices):** activities on **onboarded** Windows/macOS devices — copy records to USB, copy to

network share, print, upload to unallowed cloud apps/browsers, copy to clipboard, paste to browser. **Requires onboarding and the right licensing.**

• **On-premises / Fabric / Power BI / cloud apps (Defender for Cloud Apps):** additional locations that may

be available depending on licensing — **verify availability in your tenant.**

The simulate→enforce journey (the core discipline)

> *Define SITs/classifiers for EU personal data → build each DLP policy in **SIMULATION** (no user impact) → measure hit volume and false positives in **Activity Explorer / DLP alerts** → **tune** (confidence, instance count, keywords, EDM, exceptions) → re-simulate until false positives are acceptable → enable with **policy tips + allow-override/justification** in a **pilot ring** → validate → expand to **enforce (block)** per the DPO/legal action determination → operate (triage alerts, review overrides, re-tune).*

What you can control

• Which SITs/classifiers detect personal data and at what **confidence** and **instance count** they trigger (e.g. a single national ID vs a bulk data-subject list).

• Which **locations** each policy covers and which users/sites/groups are **included or excluded** (e.g. an HR or DPO function may be treated differently from general staff).

• The **action** per data category (audit → tip → justify → block) — set per the DPO/legal determination.

• Whether the policy adds **transfer awareness** (condition *recipient is external* / non-EU) for cross-border movement — the *legal* treatment of that transfer stays with legal.

• Whether users get **policy tips**, can **override** with justification, and what the override says.

• The **pilot ring** enforced first and the simulation dwell time before enforcement.

Limitations (be honest with buyers)

• **Endpoint DLP requires onboarded devices and the appropriate licensing** (verify your plan — endpoint DLP and several advanced classifiers are gated behind E5 / the E5 Compliance add-on). A Devices-location policy is inert until onboarding is complete.

• **Some features are in preview** and portal paths **evolve** — this pack flags "verify your licensing/tenant" rather than asserting availability that may differ in your tenant.

• DLP inspects **content it can classify**; strongly encrypted or unrecognised file formats, or content below the confidence/instance threshold, will not match. DLP is one control among several, not a guarantee.

• **The GDPR treatment of any given content — lawful basis, special-category status, whether a transfer is restricted, the retention position, the enforced action — is a data-protection/privacy/legal decision**, not a technical default. This pack configures and proves the control; the determination is deferred.

Naming convention (used in every doc and script)

Every artifact this solution creates uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
Custom sensitive info type (national ID / data-subject ref)	`EU National ID – Custom SIT – GDPR`
EDM schema / SIT (data-subject records)	`Data Subject Records – EDM – GDPR`
Email DLP policy (simulation)	`DLP – Email EU Personal Data – Simulation`
Cloud DLP policy (simulation)	`DLP – SPO+OneDrive+Teams EU Personal Data – Simulation`
Endpoint DLP policy (simulation)	`DLP – Endpoint EU Personal Data – Simulation`
Enforced pilot policy	`DLP – All Locations EU Personal Data – Enforce Pilot`
Pilot user ring	`GDPR DLP Pilot Ring – Stage1`
Policy-tip / override text	`GDPR DLP Notice – Standard – AllPolicies`
Incident/alert workflow	`GDPR DLP Alerts – Triage – Operations`

The standard deployment model

> ***Assess*** *current personal-data exposure and classification intent →* ***Design*** *SITs/classifiers, policies, and user experience →* ***Configure*** *SITs and policies* ***in simulation*** *→* ***Pilot*** *(simulate → tune → enforce to a ring) →* ***Validate*** *against pass/fail gates (personal data blocked, false-positive rate low, incidents handled) →* ***Expand*** *to the intended scope and ongoing operations. Every high-impact change is piloted in simulation first, with a documented rollback.*

2. Requirements — GDPR / PII DLP Pack (Microsoft Purview)

These are the **solution-specific** prerequisites for implementing GDPR/PII-aligned personal-data DLP across endpoint, cloud, and email. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP

- **Description:** DLP for **Exchange/SharePoint/OneDrive/Teams** and **built-in SITs** (including the

EU/GDPR SIT set) is broadly available, but **Endpoint DLP**, **advanced/custom classifiers**, **Exact Data Match**, and **trainable classifiers** are **plan-gated** — typically **Microsoft 365 E5** or the **E5 Compliance** add-on (some capabilities are in **preview**). This extends GR-#1 with the DLP-specific plan detail.

- **Why required:** A DLP policy scoped to a location or using a classifier your plan doesn't include will not

function. Endpoint DLP and EDM in particular are E5/E5-Compliance capabilities.

- **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons (E5 / E5

Compliance); in the **Purview portal** → **Data Loss Prevention** confirm the **Endpoint DLP** and **Devices** location and the classifier types you intend to use are visible. **Flag "verify your licensing/tenant"** — availability evolves.

- **How to implement if missing:** Acquire/assign the required licensing before building endpoint or

advanced-classifier policies; scope the initial rollout to features your plan covers.

2.2 DLP-specific least-privilege roles

- **Description:** The **DLP role groups** in the Purview portal — **Compliance Administrator** or

Compliance Data Administrator to create/manage DLP policies, **DLP Compliance Management** for policy management, **View-Only DLP Compliance Management** for read-only review, and the **Data Loss Prevention** role for alert/incident handling. Global Administrator only where genuinely required. Extends GR-#2.

- **Why required:** Purview enforces fine-grained role groups; DLP configuration and alert triage require the

matching role, and least privilege keeps the blast radius small — especially important because alert evidence itself contains personal data (a GDPR data-minimisation obligation on the control's own records).

- **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (or Microsoft Purview

roles) — confirm your account's role-group membership includes the DLP roles you need.

- **How to implement if missing:** Assign the least-privilege DLP role group under change control; separate

policy authors from alert triagers where possible.

2.3 Devices onboarded to Purview for Endpoint DLP

- **Description:** Endpoint DLP monitors activities on **onboarded Windows 10/11 and macOS devices** — staff

laptops are the endpoints where personal data is copied to USB, printed, or uploaded. Onboarding is done in **Purview portal** → **Settings** → **Device onboarding** (or via Intune / a script / Group Policy) and is **shared with Microsoft Defender for Endpoint onboarding** — devices already onboarded to Defender for Endpoint are onboarded for Endpoint DLP.

- **Why required:** A DLP policy scoped to the **Devices** location does nothing on a device that is not

onboarded and reporting. Onboarding is the hard prerequisite for any endpoint control.

- **How to verify: Purview portal** → **Settings** → **Device onboarding** → **Devices** shows onboarded devices;

confirm target devices appear and are reporting.

- **How to implement if missing:** Onboard devices via the Purview device-onboarding package, Intune, or

Group Policy; confirm the minimum OS build and any required Antimalware/AV state per Microsoft docs before scoping endpoint policies.

2.4 A personal-data classification intent and an EU-PII SIT inventory

- **Description:** A documented view of **which personal data and identifiers you are protecting** —

national ID / social-security-equivalent numbers, passport and tax (TIN) numbers, driver's-licence numbers, financial account/IBAN/debit-card data, contact details, and any **special-category (Article 9)** data — mapped to the **SITs/classifiers** that detect them. Reuse the **EU/GDPR built-in SITs** where they fit (e.g. *EU National Identification Number*, *EU Passport Number*, *EU Tax Identification Number (TIN)*, *EU Social Security Number or Equivalent ID*, *IBAN*, *All Full Names*), per-country SITs for the member states you operate in, and a **custom SIT / EDM / trainable classifier** for local references and special-category categories. Extends GR-#4.

- **Why required:** DLP policies key off SITs; the EU is many identifier schemes, and internal references and

special-category data have no clean built-in detector — without the right SITs (and knowing at what confidence/instance count they should fire) policies are guesswork and generate false positives.

- **How to verify: Purview portal** → **Data classification** → **Classifiers** → **Sensitive info types** lists

built-in and custom SITs; confirm the EU set and any custom ones you need exist (or are planned). Confirm the data categories, the member states in scope, and identifier formats with the DPO/data owners.

- **How to implement if missing:** Build the SIT inventory (this solution's Discovery script assesses EU-PII

built-in SIT coverage); plan an `EU National ID – Custom SIT – GDPR` for any bespoke scheme and, where near-zero false positives are required, a `Data Subject Records – EDM – GDPR` schema.

2.5 Source data for Exact Data Match (only if EDM is used)

- **Description:** For **EDM** SITs, a **sensitive data table** (e.g. an export of the data-subject / CRM /

HR records) and a workstation with the **EDM Upload Agent** to hash and upload it — the raw data never leaves your control; only salted hashes are uploaded.

- **Why required:** EDM matches against *your actual data-subject records*, which is what drives false

positives to near zero — but it requires the schema, the hashed upload, and a **refresh cadence** as the data set changes. (Uploading a hash of a personal-data table is itself a processing activity — confirm the lawful basis/DPO position for it.)

- **How to verify:** Confirm the source table, the EDM schema, the upload agent host, and a scheduled

refresh. **Purview portal** → **Data classification** → **Exact data matches** shows configured EDM schemas.

- **How to implement if missing:** Define the EDM schema and refresh process (*which* fields are in scope is

deferred to the DPO/data owner); if EDM is not in your plan or not needed, use a custom SIT with confidence/keyword tuning instead.

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific)

- **Description:** A named **pilot user/device ring** (`GDPR DLP Pilot Ring – Stage1`), an agreed

simulation dwell time (how long each policy runs in simulation before enforcement — long enough to capture representative traffic, ideally spanning a normal business cycle), and the **change-control window** for moving simulation → enforce. Extends GR-#6.

- **Why required:** DLP is high-impact where personal data moves constantly (sales, HR, support, marketing);

enforcing without a simulation baseline and a limited ring is how DLP breaks the business. The house model mandates **simulation first**, then a ring, then expand.

- **How to verify:** Confirm the pilot ring membership, that **simulation mode** is selected on each new

policy, and the approval path to enforce.

- **How to implement if missing:** Define the ring and dwell time and agree change control before enabling

any enforcement action.

2.7 An incident/alert triage owner and destination

- **Description:** A named owner (or queue) for **DLP alerts** raised in **Purview portal → Data loss

prevention → Alerts **(`GDPR DLP Alerts – Triage – Operations`**), plus where DLP events are reviewed (**Activity Explorer**) and, optionally, where they are forwarded (SIEM/Microsoft Sentinel via the Office 365 Management Activity API / Defender connectors). Severity and response actions defined. Because alert evidence contains personal data, the triage owner must hold the appropriate least-privilege role, and the workflow should feed the organisation's**
personal-data-breach assessment** process (a DPO/legal call on whether a match is a notifiable breach).

- **Why required:** A DLP match with no one to triage it is not a control. Alerts and Activity Explorer are

where matches surface; someone must own triage, severity, and response — and a real personal-data exposure may trigger GDPR breach-notification timelines that only the DPO/legal function can judge.

- **How to verify:** Confirm the triage owner/queue, the alert-severity scheme, any SIEM forwarding, and the

hand-off path to the DPO/breach process.

- **How to implement if missing:** Assign the owner, define severity/response and the DPO hand-off, and

(optionally) wire SIEM forwarding before enforcement generates real alerts.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	DLP/Endpoint licensing (E5 / E5 Compliance; verify)	Endpoint & advanced classifiers available
2.2	DLP least-privilege roles	Author + triage roles assigned; evidence access minimised
2.3	Devices onboarded to Purview	Endpoint location functional
2.4	Personal-data classification intent + EU-PII SIT inventory	Policies key off correct SITs
2.5	EDM source data + agent (if used)	Near-zero-FP matching for real records
2.6	Pilot ring + simulation dwell + change control	Simulate-first enforced
2.7	Alert/incident triage owner + DPO/breach hand-off	Matches are acted on

> ***Deferred to data-protection / privacy (DPO) / compliance / legal:*** *lawful basis, special-category (Article 9) status, whether a transfer is a restricted cross-border transfer and its safeguard, retention position, the enforced action per category, the acceptable false-positive threshold, and whether a given match is a notifiable personal-data breach. This solution provides the technical configuration and evidence, not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with*

hardcoded credentials or secrets.

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — GDPR / PII DLP Pack (Microsoft Purview)

This is the exact, ordered procedure to implement GDPR/PII-aligned personal-data DLP across **email, cloud, Teams, and endpoint** — every policy built in **SIMULATION** first, tuned, then enforced in a ring, then expanded. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

Automation. *The five delivered PowerShell tools run through* ***Security & Compliance PowerShell*** *(*`Connect-IPPSSession`*) and* ***Microsoft Graph****. They are* ***read-only or*** `-WhatIf` ***by default****; writes require an explicit* `-Commit` *switch. No credentials are stored in code.*

Determinations deferred. *Lawful basis,* ***special-category (Article 9)*** *status, whether a transfer is a* ***restricted cross-border transfer****, the retention position, and the *enforced action* per category are* ***data-protection / privacy (DPO) / legal*** *decisions. This guide configures and proves the control; capture those decisions before Phase 3.*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','InformationProtectionPolicy.Read' -NoWelcome
```

1. **Run the posture assessment** (delivered script #1, read-only):

```
.\DLPGDPR-Discovery.ps1 -CsvPath .\DLPGDPR-Posture.csv
```

It reports existing DLP policies and their mode, built-in vs custom SIT coverage (including which of the **EU/GDPR built-in SITs** are present and whether a custom national-ID/data-subject SIT already exists), and licensing/endpoint readiness signals.

1. **Confirm licensing and endpoint readiness** (Req 2.1, 2.3): confirm E5/E5-Compliance where endpoint or

advanced classifiers are needed, and that target staff devices are **onboarded**.

Pass/fail gate: you have a written baseline (existing policies + modes), a SIT coverage map for EU personal data, and confirmed licensing + endpoint onboarding for the locations you will target. **Rollback:** none (read-only).

Phase 1 — Design the classification layer (SITs & classifiers for EU personal data)

Decide, per in-scope data category, which detector applies. Do **not** invent SITs — use built-in where they fit; build custom/EDM/trainable only for gaps. *Whether a regulatory (e.g. GDPR-labeled) DLP policy template is available is version-/licensing-dependent — check the template gallery, but do not rely on one existing.*

1. **Map the EU/GDPR built-in SITs first.** In **Purview portal → Data classification → Classifiers →

Sensitive info types**, confirm the built-in SITs for your categories and the member states you operate in — e.g. *EU National Identification Number*, *EU Passport Number*, *EU Social Security Number or Equivalent ID*, *EU Tax Identification Number (TIN)*, *EU Driver's License Number*, *EU Debit Card Number*, *International Banking Account Number (IBAN)*, *All Full Names*, and the relevant per-country variants. Note each SIT's** confidence levels **and default** instance count**.

1. **Author a custom SIT for any bespoke identifier.** Where a national scheme isn't covered by a built-in

SIT, or you protect an internal data-subject reference, create `EU National ID – Custom SIT – GDPR` with a **regex primary pattern** matched to the format, **supporting keywords** (e.g. "national ID", the member-state term, "customer ID"), a **confidence level**, and a **character proximity**. Portal: **Classifiers** → **Sensitive info types** → **Create sensitive info type**. Test it against sample text in the wizard's **Test** step with fabricated IDs.

1. **Configure EDM where near-zero false positives are required** (Req 2.5). Define the schema

(`Data Subject Records – EDM – GDPR`), hash-and-upload the data-subject/CRM/HR export with the **EDM Upload Agent**, and set a **refresh cadence**. Portal: **Data classification** → **Exact data matches**. *Which fields are in scope is the DPO/data owner's determination.*

1. **Add trainable classifiers for special-category / conceptual data** (Article 9 — e.g. health,

biometric-context content) where a pattern SIT can't fit — use a built-in trainable classifier where one fits, or train a custom one on sample content. Verify availability against your plan. *What counts as special-category data is a DPO/legal determination.*

Pass/fail gate: every in-scope data category maps to a named, tested SIT/classifier at a chosen confidence and instance count; the custom SIT matches fabricated IDs and does not match unrelated numbers. **Rollback:** delete unused custom SITs/EDM schemas (they have no effect until referenced by a policy).

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact)

Create **one policy per location group**, each in **simulation mode**. Simulation evaluates the policy against real traffic and records what *would* match, with **no** enforcement and (optionally) with policy tips shown.

1. **Email DLP policy —** `DLP – Email EU Personal Data – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** → custom (or a regulatory template if one applies in your tenant) → **Locations: Exchange email only** → rule: condition *Content contains* the EU-personal-data SITs from Phase 1 (national-ID SITs, TIN, IBAN, and/or the EDM SIT) at the chosen confidence/instance count; optionally add *Recipient is external* for cross-border/transfer awareness → action *Restrict access or encrypt* (kept inert by simulation) → **Policy mode: Run the policy in simulation mode** (optionally *with policy tips*). Finish.

1. **Cloud DLP policy —** `DLP – SPO+OneDrive+Teams EU Personal Data – Simulation`**.**

Same flow → **Locations: SharePoint sites, OneDrive accounts, Teams chat and channel messages** → conditions as above → action *Restrict access* (block external sharing on match) → **simulation mode**.

1. **Endpoint DLP policy —** `DLP – Endpoint EU Personal Data – Simulation` (requires onboarded devices +

licensing). Same flow → **Locations: Devices** → conditions as above → **endpoint activities to audit/restrict**: *copy to USB/removable media*, *copy to network share*, *print*, *upload to unallowed cloud apps/browser*, *copy to clipboard*, *paste to browser* → **simulation mode**. Confirm the Devices location is selectable (if not, revisit licensing/onboarding — Req 2.1/2.3).

1. **Set the user experience** consistently: define `GDPR DLP Notice – Standard – AllPolicies` policy-tip

text (in plain business language — *why* this was flagged and *what to do*) and enable **allow override with justification** where the DPO/legal function permits — but note tips/overrides only *appear* once a policy is enforced; in simulation they are captured, not shown to end users unless "simulation with policy tips" is selected.

1. **Verify with the config helper** (delivered script #2, `-WhatIf` by default):

```
.\DLPGDPR-Config.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' `
    -Locations Exchange -SensitiveTypes 'EU National Identification Number' -MinCount 5 -Confidence Hi
```

Run with `-Commit` only to apply an intended change; the script never leaves a policy in enforce mode.

Pass/fail gate: all three policies exist and are confirmed in **simulation** (script #1/#3 report `Mode = TestWithoutNotifications / TestWithNotifications`, i.e. simulation), scoped to the correct locations and EU-personal-data SITs. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is clean.

Phase 3 — Measure and tune (drive false positives down)

Let each policy run in simulation for the agreed **dwell time** (Req 2.6) to capture representative business traffic (sales, HR, support, marketing).

1. **Review what matched. Purview portal** → **Data loss prevention** → **Alerts** (simulation alerts) and

Data classification → **Activity explorer** (filter to DLP activities) show every simulated match with the file/message, the SIT, and the confidence. Export with the reporting script:

```
.\DLPGDPR-Report.ps1 -Days 14 -CsvPath .\DLPGDPR-Matches.csv
```

1. **Classify each match** as true positive or **false positive** and identify the false-positive drivers

(e.g. a national-ID SIT firing on unrelated numbers of the same length, or an IBAN-shaped internal reference). Where a match is real personal data leaving the organisation, note whether it is an *external/cross-border* transfer — the *legal* treatment of that transfer is a DPO/legal call, not a detector fault.

1. **Tune** to reduce false positives without losing true positives:

• Raise the **confidence level** (e.g. medium → high) so only high-confidence matches count.

• Raise the **instance count** (e.g. require ≥5 identifiers, not 1) to focus on bulk data-subject leaks.

• Add **supporting keywords / proximity** to the custom SIT so context is required.

• Introduce **EDM** (`Data Subject Records – EDM – GDPR`) for categories where pattern SITs over-match.

• Add **exceptions** (e.g. exclude a DPO/HR mailbox or site the privacy function has scoped out) where

justified.

1. **Re-simulate** after each tuning change and re-measure. Repeat until the false-positive rate meets the

validation gate (see Testing).

Pass/fail gate: measured false-positive rate is at/under the agreed threshold on the simulation sample, with true positives (real personal-data leaks) still detected. **Rollback:** revert the last tuning change (script #2 `-WhatIf` shows the diff before `-Commit`).

Phase 4 — Enforce in a pilot ring (Pilot)

1. **Scope to the pilot ring.** Add `GDPR DLP Pilot Ring – Stage1` (users) and pilot devices as the

included scope on each policy (all other users/devices excluded for now):

```
.\DLPGDPR-Set-Scope.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' `
    -PilotRingGroup 'GDPRDLPPilotRing@contoso.com' -Location Exchange -Commit
```

1. **Move the ring to enforcement.** Change **Policy mode** from *simulation* to **Turn it on / Enforce**.

Start with **policy tips + allow-override (justification)** rather than hard block, so pilot staff can report false negatives/positives while retaining a business escape hatch for legitimate personal-data handling.

1. **Confirm enforcement is live** for the ring only (script #3 reports mode `Enable` and the scoped

identities). Confirm end users in the ring now see the `GDPR DLP Notice – Standard – AllPolicies` tip on a test match (fabricated data).

1. **Handle incidents.** Wire `GDPR DLP Alerts – Triage – Operations`: assign the alert owner/queue

(Req 2.7), set severities, define the **DPO/breach hand-off** for real exposures, and (optionally) forward to SIEM/Sentinel. Triage a real simulated/pilot alert end-to-end to prove the workflow — and confirm alert evidence is only accessible to appropriately-roled staff (personal-data minimisation on the control's own records).

Pass/fail gate: the pilot ring is enforced (tips shown, overrides captured), matches raise alerts, and the triage workflow produces a dispositioned incident with the DPO hand-off exercised. No enforcement outside the ring. **Rollback:** set the policy back to **simulation mode** (single setting) — instantly removes enforcement with no data change.

Phase 5 — Expand and harden (Enforce → Operate)

1. **Expand scope** from the ring to the full intended population once the pilot gate passes, keeping

documented exclusions (e.g. the DPO/HR function if scoped differently by the privacy function).

1. **Escalate the action** per the DPO/legal determination — e.g. move a category from *tip + override* to

block where required (external/cross-border sharing of national-ID or special-category data) — one category/location at a time, re-validating after each.

1. **Operationalize:** schedule the reporting script for a recurring false-positive/alert review, review

user overrides (are staff justifying legitimately or bypassing?), refresh **EDM** data on cadence, and re-tune as data and behaviour change.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail

evidence.

Pass/fail gate: enforcement live across the intended scope with the DPO-mandated action per category; false-positive rate steady/low; alerts triaged on cadence with breach hand-off; overrides reviewed.

Rollback: any policy can be returned to **simulation** at any time as an immediate, non-destructive safety switch; individual policies can be disabled without affecting others.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline, confirm licensing/onboarding	Posture CSV	Baseline + readiness confirmed	n/a (read-only)
1 Design	Map EU built-in SITs, build custom SIT / EDM / classifiers	Custom SIT / EDM schema	Every category → tested detector	Delete unused SIT/EDM
2 Configure	Build 3 policies in **simulation**	Email/Cloud/Endpoint sim policies	All in simulation, correct scope	Delete sim policy
3 Tune	Measure + reduce false positives	Matches CSV	FP rate ≤ threshold	Revert tuning change
4 Pilot	Enforce to ring, wire alerts + DPO hand-off	Pilot ring, alert triage	Ring enforced, incident dispositioned	Back to simulation
5 Expand	Broaden scope, escalate to block, operate	Enforced policies	Full-scope enforce, low FP, alerts triaged	Simulation / disable

5. Testing & Validation — GDPR / PII DLP Pack (Microsoft Purview)

Validate the personal-data DLP implementation against explicit **pass/fail gates**. The three headline gates are: **(A) personal-data leaks are blocked**, **(B) the false-positive rate is low**, and **(C) incidents are handled**. Run every test with **non-real, clearly-fake sample data** — fabricated national-ID/IBAN values, Microsoft-documented test patterns, and dummy names — **never real personal data or data-subject records**. Record the evidence.

> *All tests assume the policies from the Implementation Guide, first proven in **simulation** and then enforced to the **pilot ring**. Endpoint tests require an **onboarded** device (Req 2.3).*

Test A — Detection & enforcement (personal-data leaks are blocked)

#	Test	Steps	Pass condition
A1	Email match blocked	From a pilot-ring user, send an email to an **external** recipient containing a fabricated list with enough fake national-ID/IBAN values to meet the threshold.	Message is blocked/encrypted per the enforced action; sender sees the policy tip; a DLP alert is raised.
A2	SharePoint/OneDrive external share blocked	As a ring user, upload a fake data-subject file with the EU-personal-data SIT and attempt to share it **externally**.	External sharing is blocked/restricted on match; event appears in Activity Explorer.
A3	Teams message match	Paste fabricated national-ID/personal-data content into a Teams chat/channel covered by the policy.	Message is blocked or tipped per the enforced action; event logged.
A4	Endpoint — USB copy	On an onboarded ring device, copy a fake data-subject file to **removable media**.	Activity is audited/blocked per policy; endpoint DLP event appears in Activity Explorer.
A5	Endpoint — print / cloud upload	On the ring device, attempt to **print** the fake data-subject file and **upload** it to an unallowed cloud app/browser.	Each activity is audited/restricted per policy; events logged.
A6	Cross-border / external-recipient awareness	Send the fabricated personal-data file to an **external** recipient where the *recipient is external* condition is configured.	The external-transfer condition contributes to the match / raises the flagged action; internal-only send behaves per its own rule.
A7	Below-threshold negative	Send content with **fewer** identifiers than the threshold (or lower confidence).	Correctly **not** matched — confirms the threshold/confidence tuning holds.

Gate A (pass): A1–A6 each produce the enforced action and a logged event; A7 correctly does not match.

Test B — False-positive rate (adoption gate)

#	Test	Steps	Pass condition
B1	Simulation FP baseline	Over the agreed dwell time, export simulation matches (`DLPGDPR-Report.ps1 -Days <n>`) and classify each as TP/FP.	**False-positive rate ≤ the agreed threshold** (define with the DPO/privacy function; a common target is ≤10% of matches, or an absolute FP count the triage team can absorb).
B2	Legitimate-traffic negative	Run representative legitimate business content (no real personal data) through the covered channels — internal reference numbers, non-record documents.	Legitimate traffic is **not** matched — no spurious tips/blocks.
B3	Custom-SIT precision	Send documents containing unrelated numbers of the same length as a national ID / IBAN but with no supporting keywords.	The `EU National ID – Custom SIT – GDPR` does **not** fire without its keyword/proximity context.
B4	Post-tuning re-measure	After each tuning change (confidence↑, instance count↑, keywords, EDM, exceptions), re-simulate and re-measure.	FP rate trends **down** while true positives (Test A) still fire.
B5	Override sanity	In the pilot ring, review captured **allow-with-justification** overrides.	Overrides are legitimate business justifications, not routine bypass — if routine, re-tune or re-scope.

Gate B (pass): measured FP rate at/under threshold on the simulation sample with true positives intact.

Test C — Incident / alert handling (the control is operable)

#	Test	Steps	Pass condition
C1	Alert raised	Trigger a policy match (Test A1/A4).	A DLP **alert** appears in **Purview** → **Data loss prevention** → **Alerts** with the correct policy, severity, and evidence.

#	Test	Steps	Pass condition
C2	Triage workflow	The `GDPR DLP Alerts – Triage – Operations` owner/queue picks up the alert, sets status, and dispositions it.	Alert moves through the defined states to a resolved disposition by the named owner.
C3	Breach hand-off	For a match representing a real personal-data exposure, exercise the hand-off to the **DPO/breach-assessment** process.	The DPO/legal function receives the evidence and records the breach-notification determination (the determination itself is theirs, not the control's).
C4	Activity Explorer trail	Locate the same event in **Data classification** → **Activity explorer**.	Full evidence trail present (user, location, SIT, action) for investigation.
C5	Evidence access control	Confirm who can view the alert evidence (which contains personal data).	Only appropriately-roled staff can view; least-privilege / data-minimisation holds (Req 2.2/2.7).
C6	SIEM forwarding (if configured)	Confirm the DLP event reaches the SIEM/Sentinel destination (Req 2.7).	Event present in the downstream system with usable fields.

Gate C (pass): matches raise alerts, alerts are triaged to disposition by the owner with least-privilege evidence access, the DPO/breach hand-off works, and the trail (and SIEM forward, if used) is present.

Simulation-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Users/devices **outside** `GDPR DLP Pilot Ring – Stage1` experience no blocking during pilot.
S2	Instant rollback	Setting any enforced policy back to **simulation mode** immediately removes enforcement with no data change (verify a previously-blocked action now only simulates).

#	Test	Pass condition
S3	Scripts are safe-by-default	`DLPGDPR-Config.ps1` and `DLPGDPR-Set-Scope.ps1` run **without** `-Commit` make no change (`-WhatIf` output only); discovery/validate/report scripts are read-only.

Evidence to capture (for the deliverable record)

• Baseline posture CSV (Phase 0) and the EU-personal-data SIT coverage map.

• Simulation match export + TP/FP classification and the computed **false-positive rate** before/after tuning (Gate B).

• Screenshots/log of Test A enforcement actions and the raised alerts (Gate A/C).

• The dispositioned incident from Test C2, the DPO/breach hand-off record (C3), the evidence-access confirmation (C5), and, if used, the SIEM forward (C6).

• Confirmation that outside-ring users were unaffected (S1) and that simulation rollback works (S2).

> ***Determination boundary.*** *These tests prove the **control works**. Whether a given data category's enforced action, its special-category/lawful-basis treatment, whether a transfer is restricted, and the acceptable FP threshold are *acceptable* is a data-protection/privacy (DPO)/legal sign-off, captured alongside the evidence above.*

6. Troubleshooting — GDPR / PII DLP Pack (Microsoft Purview)

Symptom-first fixes for the failures you actually hit implementing personal-data DLP across email, cloud, Teams, and endpoint. Most problems are one of: a policy not matching, the custom SIT not firing, the endpoint location unavailable, too many false positives, or matches that raise no alert.

Policy / detection

A DLP policy matches nothing even though the content clearly contains personal data.

• Confirm the policy is actually **enabled and in a mode that evaluates** — a *disabled* policy does nothing;

a **simulation** policy evaluates and logs but does not block. Check with `DLPGDPR-Discovery.ps1` (Mode column) or `DLPGDPR-Validate.ps1`.

• Check the **instance count and confidence** on the rule — if it requires ≥5 identifiers at High confidence

and your test has 1, it correctly won't fire. Lower the threshold for testing, or add more sample instances.

• **Policy propagation takes time** — newly created/changed DLP policies can take **up to ~1 hour (and longer

for some locations)** to take effect. Wait before concluding it's broken.

• Confirm the **location scope** includes where you're testing (e.g. the specific site/user), and that the

test identity isn't in an **exclusion** (e.g. a DPO/HR mailbox the privacy function scoped out).

The `EU National ID – Custom SIT – GDPR` **never matches.**

• Test the SIT's **regex + keywords** in the SIT wizard's **Test** step with a fabricated ID that matches

your format. A too-strict regex, wrong **character proximity**, or a required keyword that isn't present will suppress all matches. Loosen and re-test incrementally.

• If it matches *too much* (e.g. every number of that length), that's a precision problem, not a miss — add/

require supporting keywords ("national ID", the member-state term) and tighten proximity (see False positives below).

An EU built-in SIT (e.g. EU National Identification Number) isn't in the SIT list.

• SIT names and availability are **version-/tenant-dependent** — the exact display name may differ or a SIT

may be surfaced under a per-country name. Run `DLPGDPR-Discovery.ps1` (it probes the EU set by name) and **verify the current name in your tenant** rather than assuming; do not hand-invent a SIT name in a rule.

Matches appear in simulation but nothing is blocked.

• That is **correct** — simulation logs what *would* happen without enforcing. To block, move the policy to

enforce for the pilot ring (Implementation Phase 4). If you expected blocking, you're still in simulation.

A match to an external recipient — is it a cross-border transfer?

• DLP flags the *content* and (with the *recipient is external* condition) that it left to an external party.

Whether that is a restricted cross-border transfer, and what safeguard applies, is a DPO/legal determination — not a detector fault. Route it to the DPO hand-off (Req 2.7); don't weaken the detector.

Endpoint DLP

The Devices/Endpoint location isn't available when creating a policy.

• **Licensing:** Endpoint DLP requires the appropriate plan (E5 / E5 Compliance) — check the licensing signal

with `DLPGDPR-Validate.ps1` and **verify in the admin center**.

• **Onboarding:** the Devices location depends on **onboarded devices** — confirm in **Purview portal → Settings → Device onboarding**. No onboarded devices → the location does nothing even if selectable.

Endpoint policy is enforced but device activities (USB/print/upload) aren't caught.

• Confirm the specific **device is onboarded and reporting** (portal device list), meets the **minimum OS

build**, and — for some activities — that the required agent/AV prerequisites per Microsoft docs are met.

• Confirm the **activity is in scope** of the rule (e.g. "copy to USB" is enabled) and that the app/browser

or network path isn't on an **allowed/exception** list (e.g. a sanctioned CRM/HR tool).

• Allow for **reporting latency** — endpoint events can take time to surface in Activity Explorer.

False positives (the adoption killer)

Staff are getting policy tips on legitimate, non-personal-data content.

• Export matches with `DLPGDPR-Report.ps1 -CsvPath ...`, classify TP/FP, and identify the driver.

• **Raise confidence** (medium→high) and/or **instance count** (a single ID is often legitimate; a bulk list

is a leak) so low-signal hits don't fire.

• Add **supporting keywords/proximity** to the custom SIT so context is required, not just a number pattern.

• For a built-in SIT (or a pattern SIT) that over-matches your identifiers, move that category to **Exact

Data Match** (`Data Subject Records – EDM – GDPR`) so only your real records match.

• Add a targeted **exception** where the DPO function has justified it (specific mailbox/site) — narrowly,

with a documented reason.

• Re-simulate after each change and re-measure — don't stack multiple changes blind.

Alerts / incident handling

Policy matches occur but no alert appears / no one is notified.

• Confirm **alerts are configured** on the rule (alert on match, threshold) and check **Purview → Data loss

prevention → Alerts**. Some low-severity matches aggregate rather than alert per event.

• Confirm **audit logging is enabled** in the tenant — the report script and Activity Explorer rely on it.

• Confirm the **triage owner/queue** (`GDPR DLP Alerts – Triage – Operations`) exists and, if forwarding to

SIEM/Sentinel, that the connector is healthy (Req 2.7).

A real exposure occurred — who decides if it's a notifiable breach?

• The control raises the alert and preserves the evidence; **whether the exposure is a notifiable

personal-data breach (and the GDPR notification timeline) is a DPO/legal determination.** Ensure the triage workflow hands off to the DPO/breach process (Req 2.7) — the control does not make the breach call.

Triage staff can't see the alert evidence (or see too much).

• Alert evidence contains personal data — access is governed by **role**. Confirm the triage owner holds the

least-privilege **Data Loss Prevention / View-Only DLP** role and nothing broader (Req 2.2/2.7) — this is data-minimisation applied to the control's own records.

The report script returns no matches.

- **Audit log latency:** DLP events can take time to appear; widen `-Days` and re-run.
- Freshly created policies need **dwell time** — there may simply be no matches yet.
- Confirm **audit logging is on** and your account has the **View-Only DLP / audit** role.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

• Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth /

MFA-capable** admin.

• Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data

Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

A script made an unexpected change.

• The delivered scripts are **read-only or** `-WhatIf` **by default**; writes require `-Commit`. If a change

landed, it was committed intentionally — the config helper never leaves a policy in **enforce**, so the safe recovery is always to set the policy back to **simulation** in the portal (one setting, no data change).

Fast triage table

Symptom	First check
Policy matches nothing	Mode (disabled/sim), instance count/confidence, propagation time, scope/exclusion
Custom SIT never fires	Test regex+keywords+proximity in the SIT wizard
Custom SIT over-matches	Require supporting keywords, tighten proximity, or move to EDM
EU built-in SIT not listed	Verify current SIT name in tenant (version-dependent) — don't invent a name
Nothing blocked	Still in **simulation** — that's expected; enforce the ring to block
External-recipient match	May be a cross-border transfer — a DPO/legal call, route to breach hand-off
Devices location missing	Licensing (E5/E5 Compliance) + device **onboarding**

Symptom	First check
Endpoint activity not caught	Device onboarded/reporting, activity in scope, allowed-app/network exceptions
Too many false positives	Raise confidence/instance count, add keywords/EDM, exceptions, re-simulate
No alert on match	Alert config on rule, audit logging on, triage owner, SIEM connector
Breach or not?	DPO/legal determination — control preserves evidence, doesn't decide
Evidence access wrong	Least-privilege DLP role on the triage owner (data-minimisation)
Report returns nothing	Audit latency/dwell time, audit logging on, role
Cmdlet/connect fails	Module updated, modern auth, correct DLP role

7. Best Practices — GDPR / PII DLP Pack (Microsoft Purview)

Field-tested practices for running personal-data DLP across endpoint, cloud, and email so the control stays trusted, effective, and low-noise. These complement the Implementation and Testing guides.

Simulate before you enforce — always

• **Never** switch a new or materially changed DLP policy straight to enforce. Run it in **simulation**

first, long enough to capture representative business traffic (a normal operating cycle — Req 2.6), and read the results before enabling.

• Use **simulation with policy tips** on the pilot ring when you want staff feedback before hard block.

• Treat **simulation mode as your permanent safety switch**: any enforced policy can be returned to

simulation in one setting, instantly removing enforcement with no data change — this is your rollback.

Get the EU personal-data classification right

• **The EU is many identifier schemes, not one.** Reuse the **EU/GDPR built-in SITs** (national ID,

passport, TIN, social-security-equivalent, driver's licence, debit card, IBAN, full names) and the **per-country** variants for the member states you operate in — build custom only for genuine gaps.

• **There is no clean built-in for bespoke references** — build `EU National ID – Custom SIT – GDPR` tuned

to the local format, with **supporting keywords and proximity** so a bare number doesn't fire.

• Use **Exact Data Match** (`Data Subject Records – EDM – GDPR`) for categories where pattern SITs over-fire

— it matches your *actual* records and drives false positives toward zero, at the cost of an upload + refresh cadence. (Confirm the DPO position on hashing a personal-data table.)

• For **special-category (Article 9)** content — health, biometric-context, etc. — use **trainable classifiers** or keyword evidence, not a lone regex; *what* counts as special category is a DPO/legal call.

Tune for a low false-positive rate (adoption depends on it)

• Start at **higher confidence** and a **realistic instance count** — a single national ID is often legitimate; a bulk data-subject list in one outbound file is a leak. Bulk-exfiltration thresholds cut false positives dramatically.

• Every false positive that reaches a staff member erodes trust in **every** policy tip. Budget for a tuning cycle, not a one-time build.

• Re-simulate after each change and re-measure — don't stack multiple tuning changes blind.

Respect the GDPR determination boundary

• **DLP detects content; the DPO/legal function decides treatment.** Lawful basis, special-category status, whether a transfer is a **restricted cross-border transfer** and its safeguard, and retention are legal determinations — don't encode them into a detector; scope and action follow the compliance decision.

• Add **transfer awareness** with the *recipient is external* condition where cross-border movement is a concern, but the *legal* treatment of the transfer stays with legal.

• Where the DPO function scopes a mailbox/site out (e.g. a controlled DSAR-fulfilment workflow), implement it as a **documented exception**, not a silently weakened policy.

Right-size the user experience

• Show **clear, actionable policy tips** in plain business language — tell the user *why* and *what to do*, not a compliance error code. Reuse one standard notice (`GDPR DLP Notice – Standard – AllPolicies`).

• Prefer **allow-with-justification / override** over hard block for categories where legitimate business exceptions exist, then **review the overrides** — routine overriding means the policy is mis-scoped.

• Reserve **hard block** for the categories where the DPO function requires it (e.g. external/cross-border sharing of national-ID or special-category data); escalate to block one category at a time, re-validating.

Endpoint DLP specifics

• **Onboarding is the gate.** A Devices policy is inert until the device is onboarded (shared with Defender

for Endpoint) and reporting — verify onboarding before blaming the policy.

• Roll endpoint controls out **audit-first**: audit USB/print/cloud-upload activities before restricting, so you see real personal-data-handling patterns and avoid blocking legitimate business workflows.

• Mind **unallowed vs allowed apps/browsers and network exceptions** — configure the allowed-app and network-path lists so sanctioned CRM/HR tools aren't caught alongside exfiltration paths.

Operations & governance

• Give DLP **alerts an owner and an SLA** (Req 2.7). Match volume without triage is not a control. Wire a **DPO/breach hand-off** for real exposures so notifiable-breach timelines aren't missed. Forward to SIEM/Sentinel where central SecOps needs visibility — but keep evidence access least-privilege since it contains personal data (data-minimisation on the control's own records).

• Review **Activity Explorer** and the false-positive rate on a **recurring cadence**; re-tune as data and behaviour drift.

• Enforce **least-privilege roles** and, where possible, **separate policy authors from alert triagers**.

• **Refresh EDM data** on a schedule aligned to the source set — stale EDM data silently degrades matching.

• Keep a **change log** of every simulate→enforce transition and every action escalation, with the DPO/legal sign-off attached.

Stay inside the boundary

• DLP is **one control**, not a guarantee — it inspects content it can classify; combine with sensitivity labels, encryption, and insider-risk where the risk warrants.

• **Verify licensing/tenant** before relying on any endpoint or advanced-classifier capability, and before assuming a GDPR-labeled policy template exists — plans and portal paths evolve; don't assume a feature is present.

• **Lawful basis, special-category status, cross-border-transfer treatment, the enforced action, and the acceptable false-positive threshold per category are data-protection/privacy (DPO)/legal determinations** — you provide the technical control and the evidence; they own the decision.

8. Deliverables Summary — GDPR / PII DLP Pack (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The personal-data DLP model — SITs/classifiers (the EU/GDPR built-in set, the custom national-ID SIT and EDM, special-category trainable classifiers), the five locations (email, SharePoint, OneDrive, Teams, endpoint), policy tips/overrides, transfer awareness, the GDPR determination boundary, and the simulate→enforce journey; naming convention.
Requirements Guide	Solution-specific prerequisites (DLP/Endpoint licensing, DLP roles, device onboarding, personal-data classification intent + EU-PII SIT inventory, EDM source data, pilot ring, alert triage owner + DPO/breach hand-off) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/baseline → design EU-personal-data SITs → build policies **in simulation** → tune false positives → enforce to a pilot ring → expand; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the three headline outcomes — personal-data leaks blocked (A), low false-positive rate (B), incidents handled (C) — plus custom-SIT precision, transfer-awareness, evidence-access, simulation-first and rollback checks, all with fabricated test data.
Troubleshooting Guide	The common failure modes (policy not matching, custom SIT never fires, endpoint location missing, floods of false positives, no alerts) and how to resolve them.
Best Practices	Simulate-first discipline, EU personal-data classification, false-positive tuning, the GDPR determination boundary, user-experience design, endpoint specifics, and operations/governance.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`. No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Run mode / default safety
1	**DLPGDPR-Discovery.ps1**	DLP posture + EU-PII SIT coverage assessment: existing policies and their mode, built-in vs custom SIT coverage (incl. which EU/GDPR SITs are present and whether a custom national-ID SIT exists), licensing/endpoint readiness signals.	Read-only
2	**DLPGDPR-Config.ps1**	DLP policy configuration/remediation helper: creates/updates an EU-personal-data policy **in simulation mode** and reports the intended change.	`-WhatIf` (writes need `-Commit`; never leaves a policy in enforce)
3	**DLPGDPR-Validate.ps1**	Validation checker: confirms the GDPR policy set is in simulation, scoped to the correct locations/SITs, and (optionally) checks endpoint-location/onboarding readiness — reports pass/fail per gate.	Read-only
4	**DLPGDPR-Report.ps1**	DLP match / false-positive tuning report: exports simulation/enforcement matches for TP-vs-FP classification and rate calculation.	Read-only
5	**DLPGDPR-Set-Scope.ps1**	Scope/health helper: reports a policy's locations/mode/scope and (with `-Commit`) adjusts the included/excluded users/groups (e.g. the pilot ring).	`-WhatIf` (writes need `-Commit`)

Definition of done

- EU-personal-data SITs/classifiers mapped for every in-scope category (EU/GDPR built-in reused; `EU National ID – Custom SIT – GDPR` and, where needed, `Data Subject Records – EDM – GDPR` for gaps; trainable classifiers for special-category data).

• Email, cloud (SPO/OneDrive/Teams), and endpoint DLP policies built and **proven in simulation**.

• False-positive rate measured and tuned to at/under the agreed threshold (Gate B), with custom-SIT precision

confirmed.

• Enforcement live for the pilot ring with policy tips + override, then expanded per the DPO function's

action determination (Gate A).

• DLP alerts raised, triaged to disposition with least-privilege evidence access and a DPO/breach hand-off,

and evidence trailed in Activity Explorer (Gate C).

• Simulation-rollback and safe-by-default scripts verified; change log and DPO/legal sign-offs captured.

> ***Boundary:*** *the solution delivers the technical control and the evidence. The* ***data in scope, the lawful basis, the special-category treatment, whether a transfer is restricted, the enforced action per category, the retention position, and the acceptable false-positive threshold*** *are data-protection/privacy (DPO)/legal determinations, captured alongside the evidence.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DLPGDPR-Config.ps1

Purpose: Creates a new DLP compliance policy (and a matching content rule for one or more EU-personal-data sensitive information types — e.g. EU National Identification Number, EU Tax Identification Number, IBAN, the EU National ID custom SIT, or an EDM SIT) in SIMULATION mode, or updates an existing policy's rule, across the chosen locations (Exchange / SharePoint / OneDrive / Teams / Endpoint). Safe by default: with -WhatIf it only reports the intended change; it applies nothing unless -Commit is passed, and it NEVER creates or leaves a policy in enforce (Enable) mode — simulation only. Enforcement is a deliberate, separate portal/change-control step (a DPO/legal action determination). HOW TO RUN Preview an Exchange simulation policy for the EU National Identification Number SIT: powershell -File .\DLPGDPR-Config.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' `-Locations Exchange -SensitiveTypes 'EU National Identification Number' -MinCount 5 -Confidence High -WhatIf Actually create it (still simulation mode): powershell -File .\DLPGDPR-Config.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation'` -Locations Exchange -SensitiveTypes 'EU National Identification Number' -MinCount 5 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPGDPR-Config.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' -Locations Exchange -WhatIf Prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. .NOTES Purview — GDPR / PII DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. Expected results: -Commit creates the policy in simulation; verify a Test* Mode with DLPGDPR-Discovery.ps1 (PASS). > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), [string[]]$SensitiveTypes = @('EU National Identification Number'), [int]$MinCount = 5, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

How to run: Preview an Exchange simulation policy for the EU National Identification Number SIT: powershell -File .\DLPGDPR-Config.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' `-Locations Exchange -SensitiveTypes 'EU National Identification Number' -MinCount 5 -Confidence High -WhatIf Actually create it (still simulation mode): powershell -File .\DLPGDPR-Config.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation'` -Locations Exchange -SensitiveTypes 'EU National Identification Number' -MinCount 5 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPGDPR-Config.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' -Locations Exchange -WhatIf Prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. .NOTES Purview — GDPR / PII DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. Expected results: -Commit creates the policy in simulation; verify a Test* Mode with DLPGDPR-Discovery.ps1 (PASS). > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), [string[]]$SensitiveTypes = @('EU National Identification Number'), [int]$MinCount = 5,

[ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test.
[ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

DLPGDPR-Discovery.ps1

Purpose: Builds the GDPR/PII DLP baseline: every existing DLP compliance policy with its MODE (enforce vs simulation vs disabled) and the locations it covers, plus a summary of sensitive information types (built-in vs custom) and any EDM schemas in the tenant. Highlights which of the EU/GDPR built-in SITs are present (national ID, passport, TIN, IBAN, etc.) and whether a custom national-ID / data-subject SIT already exists. Read-only — makes no changes. Use it to see what already exists before you build simulation policies. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPGDPR-Discovery.ps1 -CsvPath .\DLPGDPR-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). .EXAMPLE .\DLPGDPR-Discovery.ps1 -CsvPath .\DLPGDPR-Posture.csv Prints the DLP policy inventory (Name, Mode, Locations) + EU-PII SIT coverage and exports the inventory CSV. .NOTES Purview — GDPR / PII DLP Pack. Read-only against Security & Compliance PowerShell. Expected results: policies you expect in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review (PASS = no unexpected Enable). > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPGDPR-Discovery.ps1 -CsvPath .\DLPGDPR-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). .EXAMPLE .\DLPGDPR-Discovery.ps1 -CsvPath .\DLPGDPR-Posture.csv Prints the DLP policy inventory (Name, Mode, Locations) + EU-PII SIT coverage and exports the inventory CSV. .NOTES Purview — GDPR / PII DLP Pack. Read-only against Security & Compliance PowerShell. Expected results: policies you expect in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review (PASS = no unexpected Enable). > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

DLPGDPR-Report.ps1

Purpose: Exports DLP rule matches (Exchange, SharePoint/OneDrive, Teams, and Endpoint) over a time window so you can classify true-positive vs false-positive and compute the false-positive rate that gates simulation-to-enforcement for the GDPR/PII policy set. Works for policies in simulation AND enforcement — simulation matches are logged the same way. Read-only — queries Search-UnifiedAuditLog only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPGDPR-Report.ps1 -Days 14 -CsvPath .\DLPGDPR-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. .EXAMPLE .\DLPGDPR-Report.ps1 -Days 14 -CsvPath .\DLPGDPR-Matches.csv Breaks matches down by workload and policy and exports a per-event CSV with a blank Disposition column. .NOTES Purview — GDPR / PII DLP Pack. Read-only reporting from the unified audit log. No changes made. Note: exported rows contain personal-data evidence — store and share the CSV under least-privilege access. Expected results: classify each row TP/FP, compute FP rate = FP / (TP+FP); PASS = rate at/under the agreed threshold. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPGDPR-Report.ps1 -Days 14 -CsvPath .\DLPGDPR-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. .EXAMPLE .\DLPGDPR-Report.ps1 -Days 14 -CsvPath .\DLPGDPR-Matches.csv Breaks

matches down by workload and policy and exports a per-event CSV with a blank Disposition column. .NOTES Purview — GDPR / PII DLP Pack. Read-only reporting from the unified audit log. No changes made. Note: exported rows contain personal-data evidence — store and share the CSV under least-privilege access. Expected results: classify each row TP/FP, compute FP rate = FP / (TP+FP); PASS = rate at/under the agreed threshold. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

DLPGDPR-Set-Scope.ps1

Purpose: Reports a DLP policy's current locations, mode, and member-of scope, and — only with -Commit — narrows an Exchange/OneDrive policy to the GDPR PILOT RING by setting the location member-of scope (ExchangeSenderMemberOf / OneDriveSharedByMemberOf), so enforcement can be limited to a ring before expansion. Safe by default: -WhatIf reports only; writes require -Commit. This helper adjusts SCOPE only — it does NOT flip a policy to enforce (that is a deliberate portal/change-control action, a DPO/legal determination). HOW TO RUN Report current scope/health: powershell -File .\DLPGDPR-Set-Scope.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' -WhatIf Restrict the Exchange policy to the GDPR pilot-ring group (still simulation mode): powershell -File .\DLPGDPR-Set-Scope.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' ` -PilotRingGroup 'GDPRDLPPilotRing@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPGDPR-Set-Scope.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' -WhatIf Prints the policy's locations/mode/scope and the Set-DlpCompliancePolicy call it WOULD run. .NOTES Purview — GDPR / PII DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. Expected results: -Commit sets the *MemberOf scope to the pilot ring; Mode is unchanged (PASS = ring scoped, still simulation). > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [string]$UserPrincipalName, [switch]$Commit)

How to run: Report current scope/health: powershell -File .\DLPGDPR-Set-Scope.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' -WhatIf Restrict the Exchange policy to the GDPR pilot-ring group (still simulation mode): powershell -File .\DLPGDPR-Set-Scope.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' ` -PilotRingGroup 'GDPRDLPPilotRing@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPGDPR-Set-Scope.ps1 -PolicyName 'DLP - Email EU Personal Data - Simulation' -WhatIf Prints the policy's locations/mode/scope and the Set-DlpCompliancePolicy call it WOULD run. .NOTES Purview — GDPR / PII DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. Expected results: -Commit sets the *MemberOf scope to the pilot ring; Mode is unchanged (PASS = ring scoped, still simulation). > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [string]$UserPrincipalName, [switch]$Commit)

DLPGDPR-Validate.ps1

Purpose: Confirms the delivered GDPR/PII DLP policies are configured as intended BEFORE and DURING pilot: each named policy exists and is in SIMULATION (Test*) mode unless deliberately enforced to the pilot ring, is scoped to the expected locations, references at least one EU-personal-data SIT, and — for the endpoint policy — the Devices location is present (a licensing/onboarding readiness signal). Emits a PASS/FAIL line per check and an overall result. Read-only — makes no changes. HOW TO RUN

powershell -ExecutionPolicy Bypass -File .\DLPGDPR-Validate.ps1 powershell -File .\DLPGDPR-Validate.ps1 -PolicyNames 'DLP - Email EU Personal Data - Simulation','DLP - Endpoint EU Personal Data - Simulation' -ExpectEnforcedRing Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPGDPR-Validate.ps1 Checks the default GDPR policy set is in simulation, scoped, and SIT-backed; prints PASS/FAIL per gate. .NOTES Purview — GDPR / PII DLP Pack. Read-only. No changes made. Expected results: every check prints PASS during the simulation build; overall PASS = all checks pass. With -ExpectEnforcedRing, an Enable mode is treated as expected (pilot enforcement) rather than a failure. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - Email EU Personal Data - Simulation', 'DLP - SPO+OneDrive+Teams EU Personal Data - Simulation', 'DLP - Endpoint EU Personal Data - Simulation'), When set, a policy in Enable (enforce) mode is treated as an EXPECTED pilot-ring state, not a FAIL. [switch]$ExpectEnforcedRing, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPGDPR-Validate.ps1 powershell -File .\DLPGDPR-Validate.ps1 -PolicyNames 'DLP - Email EU Personal Data - Simulation','DLP - Endpoint EU Personal Data - Simulation' -ExpectEnforcedRing Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPGDPR-Validate.ps1 Checks the default GDPR policy set is in simulation, scoped, and SIT-backed; prints PASS/FAIL per gate. .NOTES Purview — GDPR / PII DLP Pack. Read-only. No changes made. Expected results: every check prints PASS during the simulation build; overall PASS = all checks pass. With -ExpectEnforcedRing, an Enable mode is treated as expected (pilot enforcement) rather than a failure. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - Email EU Personal Data - Simulation', 'DLP - SPO+OneDrive+Teams EU Personal Data - Simulation', 'DLP - Endpoint EU Personal Data - Simulation'), When set, a policy in Enable (enforce) mode is treated as an EXPECTED pilot-ring state, not a FAIL. [switch]$ExpectEnforcedRing, [string]$UserPrincipalName)